

Week 10 Lab: Layer 2 Security Attacks & Countermeasures

Connect this week's lecture on switch-level attacks with practical defensive labs that let you see each attack happen and then configure the matching mitigation. You will execute a real MAC-flooding attack inside an isolated sandbox, then configure Port Security, VLAN hardening, and DHCP Snooping on Cisco switches. All offensive tasks run inside TryHackMe (AttackBox or your own VM connected to THM); all defensive tasks run in Cisco Packet Tracer. Ethical constraint: tools such as `macof`, `ettercap`, and `yersinia` must never be run against real networks.

Learning objectives

The aim of this lab is to help students understand how Layer 2 attacks work in practice and how to defend a switched network against them. By completing the activities, students will execute a MAC-flooding (CAM overflow) attack and explain how a switch fails open into hub-like behaviour; configure Port Security with sticky MAC learning and evaluate the trade-offs between `shutdown`, `restrict`, and `protect` violation modes; harden trunk interfaces against VLAN hopping (switch spoofing and double tagging) by disabling DTP, pinning an unused native VLAN, and restricting the allowed VLAN list; and implement DHCP Snooping with trusted/untrusted ports and rate limiting to defeat rogue DHCP servers and starvation attacks.

Requirements

- TryHackMe account and access to AttackBox or your own VM.
- Cisco Packet Tracer 8.x+ (free with a NetAcad account).
- Comfort with basic packet inspection (`tcpdump` / Wireshark) and Cisco IOS CLI.
- A short set of written notes for each activity (screenshots optional).

TryHackMe & Packet Tracer links

- **L2 MAC Flooding & ARP Spoofing** (TryHackMe) — <https://tryhackme.com/room/layer2>
- **Network Security & Traffic Analysis** (TryHackMe, optional refresher) — <https://tryhackme.com/room/networksecurityprotocols>
- **Packet Tracer — Switch Security Configuration (11.6.1)** — <https://www.netacad.com/resources/lab-downloads>

Suggested student workflow

1. Start with the **L2 MAC Flooding & ARP Spoofing** room to see a CAM overflow attack end-to-end. Run `sudo tcpdump -i eth1` first to observe what a sniffer sees on a healthy switch, then launch `sudo macof -i eth1` in a second session and capture again. Compare the two captures and confirm that traffic between Alice and Bob becomes visible only after the CAM table saturates.
2. Open Cisco Packet Tracer and build a small access topology (one 2960 switch, two PCs, one router). Configure **Port Security** on the access ports with `switchport port-security mac-address sticky` and `violation shutdown`; then swap a PC for one with a different MAC to trigger err-disable. Verify with `show port-security interface`.
3. Build a two-switch topology connected by a G0/1 trunk. Harden both sides against **VLAN hopping**: `switchport mode trunk`, `switchport nonegotiate`, `switchport trunk native vlan 999` (unused), and `switchport trunk allowed vlan 10,20`. Put all unused access ports into a black-hole VLAN and shut them down.
4. Extend the topology with a legitimate DHCP server (router) and a rogue DHCP server. Observe clients picking up bad configuration, then enable **DHCP Snooping**: `ip dhcp snooping`, mark the uplink to the legitimate server as `ip dhcp snooping trust`, and apply `ip dhcp snooping limit rate 15` on client ports. Release and renew leases to confirm the rogue is now blocked; inspect the binding table with `show ip dhcp snooping binding`.
5. Write short notes explaining how Port Security, DTP hardening with an unused native VLAN, and DHCP Snooping combine into a defence-in-depth posture at the access layer — and why the DHCP snooping binding table becomes the foundation for Dynamic ARP Inspection and IP Source Guard.

Note: The TryHackMe room requires a free account and grants roughly one hour of AttackBox use per day on the free tier — enough to complete the CAM overflow exercise in one sitting. Some advanced follow-up rooms may require a TryHackMe Premium subscription. Packet Tracer is free with a Cisco NetAcad account.